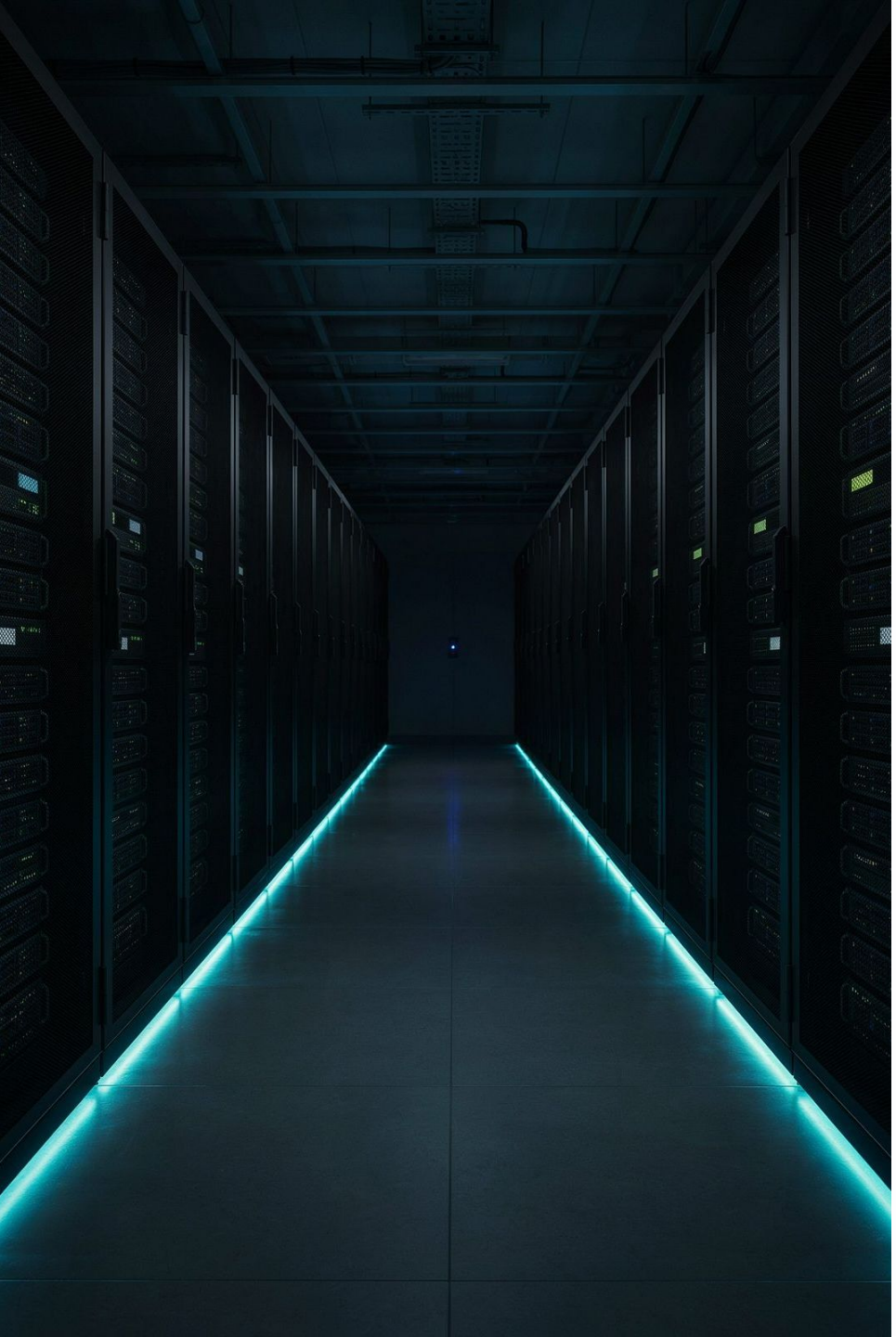


Securing AI at the Platform Level

As organizations integrate AI into their core infrastructure, security can no longer be bolted on as an afterthought. This presentation walks through a practical, end-to-end approach — from controlling who talks to your AI models, to verifying where those models came from, to proving compliance to auditors and regulators.

AI SECURITY | PLATFORM ARCHITECTURE | COMPLIANCE

Setting the Stage

Why AI Security Is Different

Traditional App Security

Protects known code paths, fixed business logic, and predictable outputs. Threats are well-understood and defenses are mature.

AI Security Challenges

AI models introduce **non-deterministic outputs**, external model dependencies, and new attack surfaces like prompt injection, model poisoning, and data exfiltration through inference. The blast radius of a single compromised model is enormous — it may serve millions of users simultaneously.

A real-world parallel: in 2023, researchers showed that a malicious system prompt could cause a customer-service chatbot to leak other users' personal data. Standard web firewalls would never have caught it.

Chapter 1

The API Gateway as Your AI Security Control Point

Every request to an AI model — whether from a mobile app, internal tool, or automated pipeline — should pass through a single, enforced gateway. Think of it as the TSA checkpoint for your AI platform: no one gets through without being screened.



What the API Gateway Enforces

The gateway is not just a traffic router. It is an active security control that inspects, authenticates, and governs every AI interaction in real time.

🔐 Authentication & Authorization

Only verified identities — users, services, or agents — can call AI endpoints. OAuth 2.0, API keys, and JWT tokens are validated on every request, preventing unauthorized model access.

🛡️ Input & Output Filtering

The gateway scans prompts for injection attacks and filters responses for sensitive data (PII, credentials). Example: a banking chatbot's gateway blocks any prompt asking it to "ignore previous instructions."

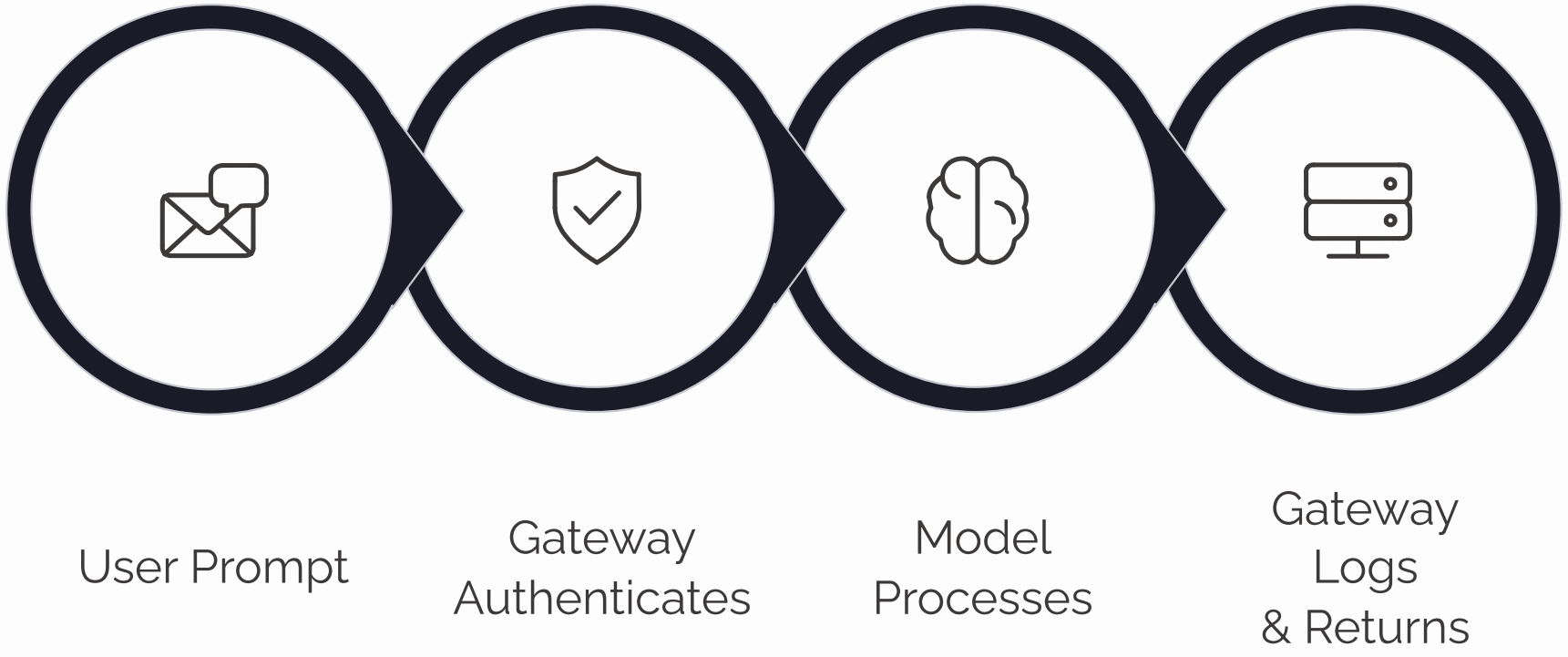
⚡ Rate Limiting & Throttling

Prevents abuse and denial-of-wallet attacks — where adversaries generate massive inference costs. Each client gets a quota; the gateway enforces it automatically.

📋 Request Logging

Every prompt and response is logged with metadata (user, timestamp, model version). This is the foundation for audit trails discussed later.

Gateway in Action: A Real-World Example

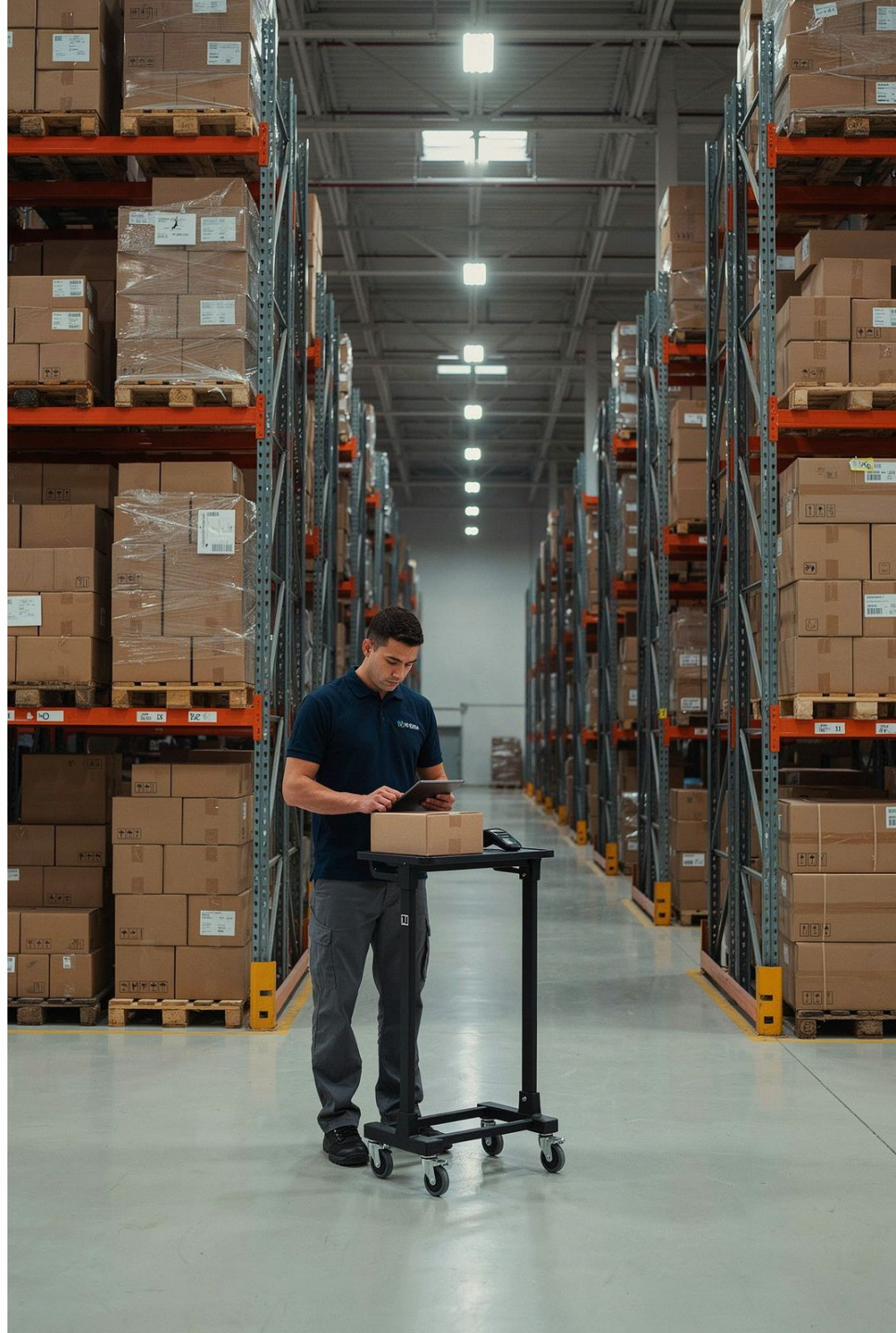


Consider a healthcare company deploying an AI assistant for clinicians. The gateway ensures only authenticated staff access the model, strips out any patient identifiers before logging, enforces a 60-requests-per-minute limit per user, and flags any response containing drug dosages for human review — all before the response reaches the clinician's screen.

Chapter 2

Model Supply Chain Security

Just as software teams worry about open-source library vulnerabilities (think Log4Shell), AI teams must secure the **model supply chain** — the full lifecycle from training data and base models to fine-tuning and deployment. A compromised model at any stage can silently undermine everything built on top of it.

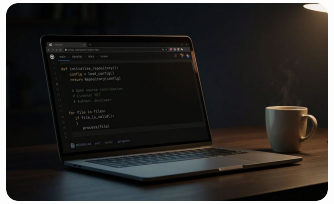


Threats Across the Model Supply Chain



Training Data Poisoning

Malicious actors inject biased or harmful examples into training datasets. Example: a spam filter model trained on poisoned data learns to allow certain phishing emails through.



Untrusted Base Models

Downloading a pre-trained model from an unverified public repository (like an unreviewed Hugging Face upload) can introduce backdoors — hidden behaviors triggered by specific inputs.



Vulnerable ML Pipelines

Training and fine-tuning pipelines that use unpatched libraries (PyTorch, TensorFlow) or insecure notebooks expose the model artifacts themselves to tampering.

Securing the Model Supply Chain

The fix mirrors best practices in software supply chain security — verify provenance, sign artifacts, and scan continuously.



Verify Model Provenance

Only use models from vetted sources. Maintain a **Model Bill of Materials (MBOM)** — analogous to a software SBOM — that records origin, training data lineage, and any fine-tuning history.



Sign and Hash Artifacts

Cryptographically sign every model checkpoint and container image. Before deployment, verify the signature to confirm the artifact has not been tampered with since it was approved.



Continuous Vulnerability Scanning

Run automated scans on model dependencies, training libraries, and serving containers in CI/CD pipelines — catching issues before they reach production.



Access Control on Model Registry

Treat your model registry like a production code repository — role-based access, mandatory peer review before promotion, and immutable version history.



Chapter 3

Audit: Building the Evidence Trail

When a regulator, an internal security team, or an incident response team asks *"what did the AI do, and when?"* — you need answers. Audit is the practice of capturing, preserving, and making searchable a complete record of AI system activity. Without it, security is unverifiable and accountability is impossible.

Compliance: Turning Audit Into Assurance

Audit logs are the raw material. Compliance is the structured process of proving, to internal and external stakeholders, that your AI platform meets required standards — whether that is GDPR, HIPAA, the EU AI Act, or your own corporate policy.

What You Must Demonstrate

- **Data minimization:** Logs do not retain raw user prompts longer than necessary
- **Access controls:** Only authorized roles can query audit logs or modify models
- **Incident response:** A documented process exists for AI-related breaches
- **Model transparency:** Stakeholders can inspect which model version served a decision

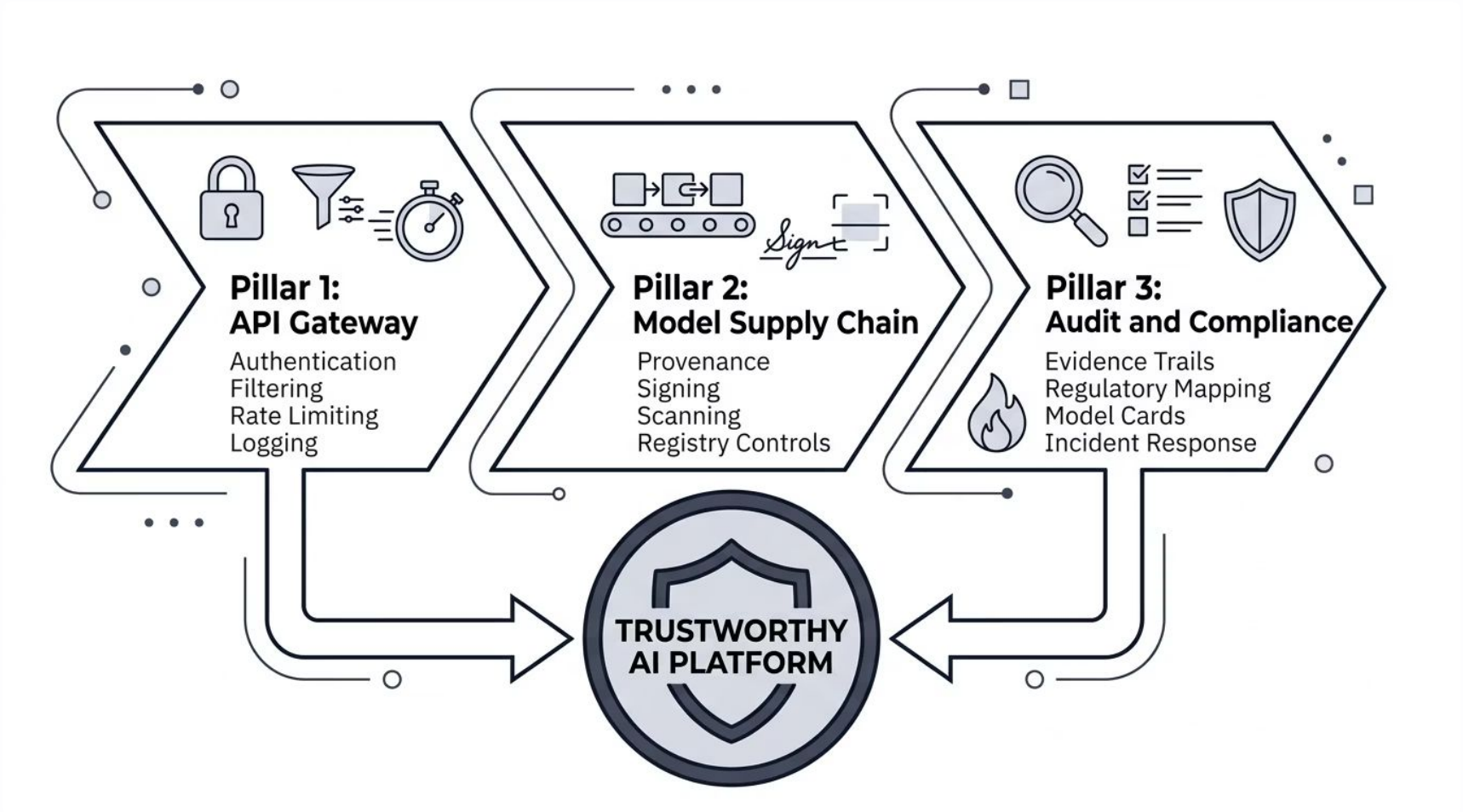
Practical Compliance Actions

- Map every AI use case to a regulatory requirement
- Automate compliance checks inside the API gateway and CI/CD pipeline
- Conduct quarterly AI risk reviews using audit log analysis
- Maintain a **Model Card** for each deployed model — documenting intended use, known limitations, and fairness evaluations

Real example: Under the EU AI Act, high-risk AI systems (e.g., credit scoring, recruitment tools) must log all inputs and outputs for a minimum of 5 years and make them available to authorities on request.

Putting It All Together

These three pillars — Gateway, Supply Chain, and Audit/Compliance — are not independent tools. They form a unified, layered defense for your AI platform.



Start with the gateway — it gives you immediate visibility and control. Then secure your model supply chain to eliminate trust gaps upstream. Finally, build your audit and compliance practice on the rich telemetry the gateway and pipeline produce. Each layer strengthens the others.